

CITS2006 - Defensive Cybersecurity

Project Task 1 Report

Security Issues in the Community

Unit Name	CITS2006 - Defensive Cybersecurity
Assessment	Project Task 1: Security Issues in the Community
Members	Faiyaz Kabir (24773532) Charlie Yin (23497868) Casey Zhu (24722864) Muhammad Afridi Ismail (24445737) Tom Jowett (24833608)
Date	13 Apr 2026

Table of Contribution

Member	Contribution
Faiyaz Kabir	Section 2.1 : Investigated cybersecurity practices in a McDonald's franchise through direct observation and research. Identified key risks including shared access control, weak password habits, privacy exposure, and limited staff awareness. Also highlighting existing strengths such as system auto-locking and network separation. Supported the analysis with real-world breach examples and proposed practical recommendations to improve access control, privacy, and cybersecurity awareness.
Charlie Yin	Section 2.2 : Conducted the full security assessment of Taning Lemon Tea, including on-site investigation, evidence collection, and identification of all vulnerabilities presented in the report. Collected and documented evidence (such as screenshots), to support each identified issue. Designed and structured the Taning Lemon Tea section of the report. Identifying and analysing default credentials, UPnP enabled, Flat network (No VLAN), AnyDesk port exposure, CCTV/NVR TCP port exposure, monitoring computer accessibility without login, lack of USB restrictions, and the observation that no major CCTV blind spots in the Taning Lemon Tea part of the report.
Casey Zhu	Section 2.2 : Contributed to writing the "Weak RFID Card System" section of the report and slide presentation, and also worked on the physical security demo covering Weak RFID Card System, Unsecured Back Door, Monitoring Computer Accessible Without Login, and No USB Restrictions. In addition, completed the CIA-based Security and Operational Impact analysis for the Router Configuration, HTTP Management Interface, and UPnP Enabled sections. Also summarised the major cybersecurity issues identified across the community entities, covering both network-level and physical-layer security concerns. Responsible for integrating and consolidating the final report and slide deck to ensure consistency, structure, and clarity across the group's work.
Muhammad Afridi Ismail	Section 2.3 : Identified and analysed key security issues within the organisation. Examined how everyday practices such as sharing keys, using weak passwords, and storing data informally could create security risks. Contributed to explaining these issues using cybersecurity concepts. Helped develop practical recommendations, such as stronger authentication, improved access control, and increased staff awareness. Focused on linking real-world practices to effective and realistic cybersecurity improvements.
Tom Jowett	Section 2.4 : Investigated cybersecurity risks within the Forged Alliance Forever community. Identified key vulnerabilities including DDoS exposure through the ICE adapter, risks from peer-to-peer networking affecting availability, and weaknesses in community moderation leading to potential social engineering attacks. Also analysed issues from outdated open-source dependencies such as DoS or remote code execution. Proposed practical recommendations including improving server protection, updating dependencies, implementing automated moderation, and increasing user awareness to enhance overall security and reliability.

1. Introduction

Cybersecurity refers to the protection of systems, networks, devices, and information from unauthorised access, misuse, disruption, or disclosure. In community settings such as restaurants, retail stores, clubs, and daycares, cybersecurity is important because even routine operations now depend on digital systems, staff accounts, mobile devices, online rosters, and stored personal information.

Community organisations are often exposed to risk through a combination of human error, weak authentication practices, poor information handling, and limited staff awareness. This report investigates several community entities through research and site observations. It identifies security issues, explains their likely impact, and proposes practical recommendations to improve security posture.

This document has been structured so each group member can contribute one community investigation using the same format. The completed section in this report focuses on a McDonald's franchise restaurant.

2. Community Investigations

2.1 McDonald's

Community Description

The investigated community is McDonald's Cannington 2, a fast-food restaurant operating under a franchise model. The site includes public dining and ordering areas, kitchen operations, a back-of-house staff entrance, and a manager's office used for administration and roster management. The workforce includes many younger employees, including teenagers and first-job workers. This makes basic cyber awareness, password hygiene, privacy handling, and supervised access especially important.

Based on observation, the store also appears to maintain multiple distinct wireless networks, including separate SSIDs for guest access, music, IoT devices, and equipment-related services. This suggests the environment does not obviously operate on a flat wireless architecture. Although this alone does not confirm full internal network segmentation, it indicates stronger separation than a single shared wireless network.

Security Issues Identified

Table 1. Summary of observed cyber-related security issues at McDonald's Cannington 2.

Issue	What was observed	Why it matters	Risk level
Shared back-door access code	The rear staff entrance uses a shared keypad code that appears not to change regularly and is known by many staff.	If current and former workers know the same code, accountability is reduced and unauthorised entry becomes harder to trace.	High
Weak staff login habits	Some six-digit login codes may be based on predictable	Short, guessable credentials weaken authentication and make	Medium–High

	information such as dates of birth.	misuse easier in a socially familiar workplace.	
Printed rosters and staff privacy exposure	Printed rosters containing names, shifts, and sometimes phone numbers may be left in clipboards accessible to staff.	Personal information can be unnecessarily exposed, creating privacy and professionalism concerns.	High
Lack of formal cybersecurity awareness training	No formal cyber awareness training was reported, despite a young workforce.	A workforce with limited awareness remains vulnerable to phishing, scams, weak passwords, and poor incident reporting.	High
Inconsistent handling of personal devices	Phones and belongings are not always stored in the designated office area.	Lost or misused devices may expose personal accounts, messages, or authentication tools.	Medium

Details and Impact of the Security Issues Identified

2.1.1 Shared Back-Door Access Code

The rear staff entrance uses a shared keypad code rather than individual authentication. Based on long-term observation, the code appears not to have changed for a substantial period and is widely known among staff. This creates a clear accountability problem. If many current or former workers know the same code, it becomes difficult to determine who accessed the site and when. In a workplace with staff turnover, this presents a meaningful risk.

This issue is not limited to physical entry. Physical access may become the first step toward wider privacy or cybersecurity problems because unauthorised entry can expose documents, internal devices, and staff-only spaces.

2.1.2 Weak Credential Habits for Staff Login

Staff sign in using a six-digit code. Although each employee is expected to use a unique code, some workers reportedly use predictable information such as dates of birth. This creates weak authentication practice because short, guessable numeric codes are easier for others to infer or misuse, especially in a workplace where staff know each other socially.

This issue becomes more serious in environments with many young employees, because convenience may outweigh security awareness. If predictable credentials are normalised, accountability and trust in the sign-in system are reduced.

2.1.3 Printed Rosters and Staff Privacy Exposure

Managers sometimes print rosters containing names, shift times, and phone numbers, and these may be left in clipboards that other workers can view. Even if this is done for operational convenience, it creates an unnecessary privacy risk. Staff contact information is personal information and should not be casually exposed in shared work areas.

This is significant because privacy harm in a workplace does not always come from an external hacker. It can also arise through internal overexposure, curiosity, misuse, or poor document handling.

2.1.4 Lack of Formal Cybersecurity Awareness Training

No formal cybersecurity training was reported, despite the store employing many younger staff. This is one of the most significant findings. Even where technical controls are relatively strong, a workforce with limited awareness remains vulnerable to phishing, weak passwords, scam calls, unsafe device use, and poor incident reporting.

This matters because many real-world breaches begin with people rather than systems. In fast-paced service environments, workers are often trained heavily on operations and customer service but receive little guidance on digital safety.

2.1.5 Inconsistent Handling of Personal Devices and Belongings

Staff are expected to keep phones in the office, but this is not always consistently followed. Some workers reportedly leave devices and belongings in other shared areas, creating opportunities for misuse, theft, or inappropriate access. Although this issue is partly physical rather than purely cyber, it still has cybersecurity relevance because phones contain accounts, messages, photos, and authentication tools.

Impact Analysis

Taken together, these issues suggest that the store's biggest risks are people-and-process risks rather than obvious infrastructure failure. The store appears reasonably secure in baseline operational terms, but shared access knowledge, weak credential habits, privacy exposure, and low cyber awareness still create meaningful vulnerabilities.

The impact of these issues includes reduced accountability for physical and digital access, greater likelihood of unauthorised entry or misuse, exposure of staff personal information, increased susceptibility to phishing and social engineering, and reputational harm if staff or applicant data were mishandled. Whitman and Mattord (2022) argue that human behaviour and weak organisational practices are common contributors to security incidents, especially when technical controls are not supported by policy and awareness.

Real-World Breach Relevance

The significance of these findings is reinforced by real-world McDonald's-related data breaches. In 2025, a McDonald's-related breach involving the McHire platform reportedly exposed approximately 64 million applicant records after attackers guessed the weak password "123456." The same report also described reused passwords and malware-based credential theft as contributing factors (Identity Theft Resource Center, 2025). This case is especially relevant because it demonstrates how weak authentication and poor credential hygiene can scale into major exposure events.

A further McDonald's breach in 2021 also showed that employee and business data can be exposed through compromised credentials and insufficient access protections. Although that case occurred in a different context, it supports the broader point that large organisations are not immune to human-factor and access-control failures.

These real-world examples do not mean the local store has the same vulnerabilities, but they show that credential weakness, overreliance on simple authentication, and people-based failures are genuine risks within the broader McDonald's ecosystem.

Diagrams

Diagram 1. CIA triad applied to the McDonald's case study

Integrity Ensure records, rosters, and accounts are not altered or misused.	Confidentiality Protect staff and applicant data from unauthorised disclosure.	Availability Keep legitimate systems and logins accessible to authorised staff.
---	--	---

The observed issues mainly threaten confidentiality (staff data exposure) and integrity (unauthorised or untraceable access), while sound authentication and reporting support availability.

Diagram 2. Simple attack flow from weak controls to harm

Weak password or shared access	Unauthorised entry or account use	Exposure of staff or applicant data	Potential misuse, scams, or privacy harm
---------------------------------------	--	--	---

This flow shows how small weaknesses at the start of the process can escalate into significant privacy and security consequences.

Recommendations

2.1.6 Replace or Strengthen Shared Door Access

The current shared keypad approach should be improved. A practical medium-term option would be individual staff access through NFC cards, app-based credentials, or unique staff PINs. A stronger long-term option would be time-restricted access tied to scheduled shifts. For example, an employee's access should only work shortly before and after their rostered shift. This is an advanced and practical mitigation because it improves both accountability and least-privilege access.

2.1.7 Rotate Shared Codes Regularly

If the keypad system must remain, the code should be changed regularly, especially after staff departures. This is a low-cost and immediately practical mitigation suited to a franchise environment where major infrastructure changes may not be locally controlled.

2.1.8 Strengthen Staff Credential Practices

The store should reinforce the use of less predictable login credentials and discourage dates of birth or obvious numeric patterns. Even if the system only supports six digits, workers should still be guided to choose non-obvious codes. This recommendation is practical because it fits the system constraints while still improving security behaviour.

2.1.9 Reduce Exposure of Printed Staff Information

Printed rosters should be handled more carefully. Phone numbers should be removed unless operationally necessary, and any roster containing staff details should be kept in controlled locations rather than left openly accessible. This is both a privacy measure and a professionalism measure. This recommendation aligns with the principle that personal information should be protected against unauthorised access and disclosure (Office of the Australian Information Commissioner [OAIC], 2022).

2.1.10 Introduce Basic Cybersecurity Awareness for Staff

A short and targeted awareness approach would be highly suitable for this store. This could include a short induction slide or toolbox talk, a one-page handout, and a poster covering phishing, scam calls, password safety, and reporting suspicious activity. This is an advanced practical mitigation because it directly addresses the main observed weakness: low cyber awareness among a young workforce.

2.1.11 Create a Simple Reporting Path

Staff should know exactly what to do if they receive a suspicious message, call, or request. A simple rule such as “stop, verify, report to the manager on shift” would provide a realistic first response. In fast-food settings, simple reporting rules are more effective than lengthy policy documents. This is consistent with broader cybersecurity guidance that recommends clear reporting and escalation processes as part of organisational security practice (Australian Cyber Security Centre [ACSC], 2023).

2.2 Taning Lemon Tea Perth

Community Description

The investigated community is Taning Lemon Tea, a small beverage shop located in Perth. The store operates using a digital point-of-sale (POS) system (Zii POS), supported by multiple connected devices including tablets, printers, CCTV systems, and online ordering platforms.

The shop relies heavily on network-connected infrastructure for daily operations such as order processing, payment handling, delivery integration (e.g., Uber Eats, Hungry Panda), and internal monitoring. Unlike larger organisations, the store does not appear to have dedicated IT management or formal cybersecurity policies in place, which may increase exposure to both cyber and physical security risks.

Security Issues Identified

Identified Vulnerabilities

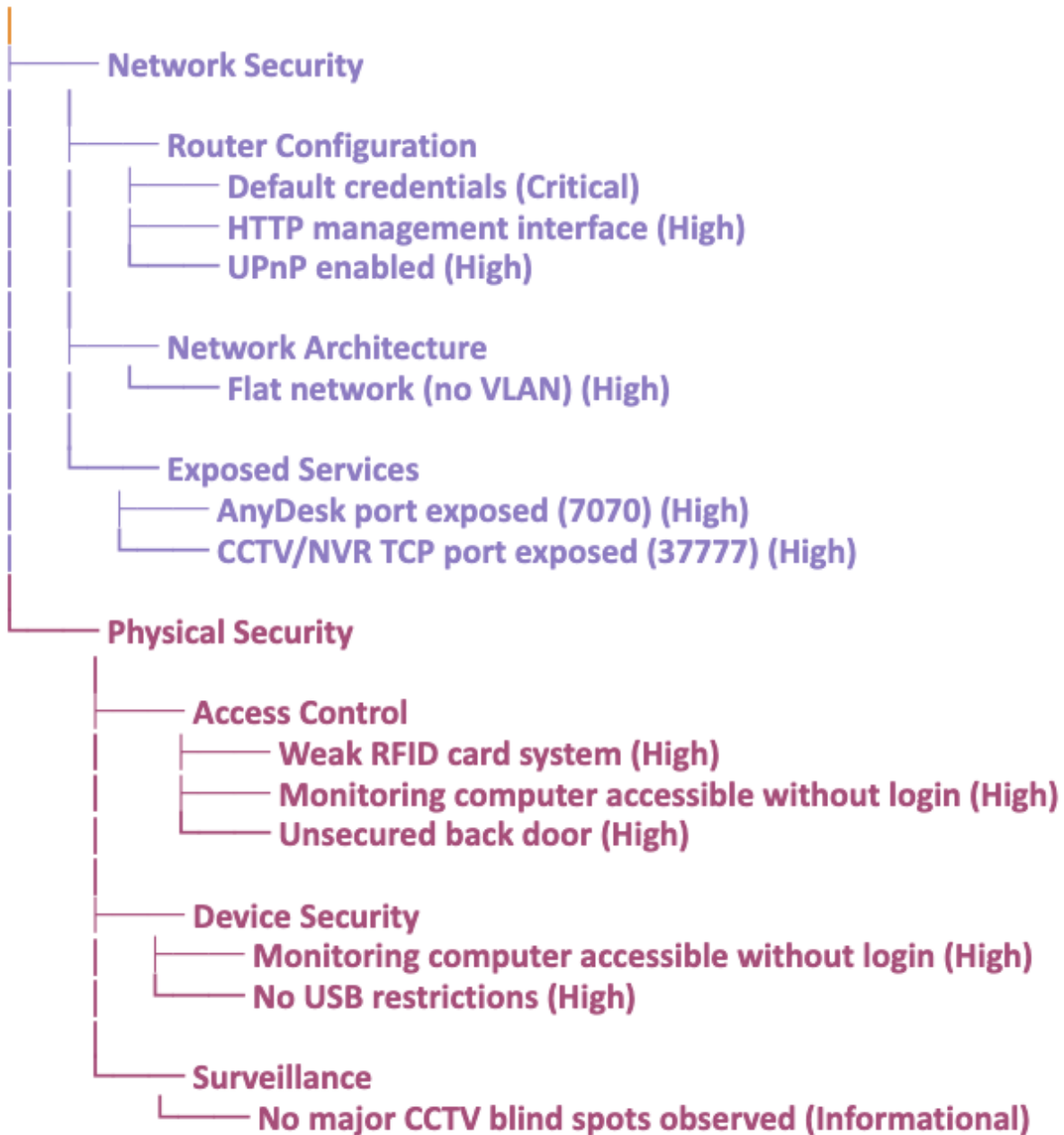


Figure 1 Overview of identified security vulnerabilities across network and physical domains

Issue	Observed Weakness	Likely Impact	Priority
Flat network architecture	All devices operate within the same subnet (192.168.1.0/24) with no VLAN or	Increased risk of lateral movement if one device is	High

	segmentation	compromised	
Default router credentials	Router uses default login credentials	Unauthorized access to network configuration and control	High
Insecure management protocol	Router and NVR management interfaces use HTTP instead of HTTPS	Risk of credential interception (confidentiality breach)	High
UPnP enabled and port exposure	UPnP exposes internal services (e.g., AnyDesk port 7070, NVR port 37777) to the internet	Increased attack surface and potential remote exploitation	High
Physical access to critical systems	Monitoring computer accessible without login or restrictions	Risk of misuse, data exposure, or tampering	High
Unsecured back door access	Back door not locked during operation; accessible via apartment entrance	Unauthorized entry into staff-only areas	High
Weak access control (RFID cards)	Low-security RFID cards vulnerable to cloning; tailgating possible	Unauthorized physical access	High

Table 2. Summary of observed cyber-related security issues at Taning Lemon Tea Perth

Details and Impact of the Security Issues Identified

Network Security vulnerabilities

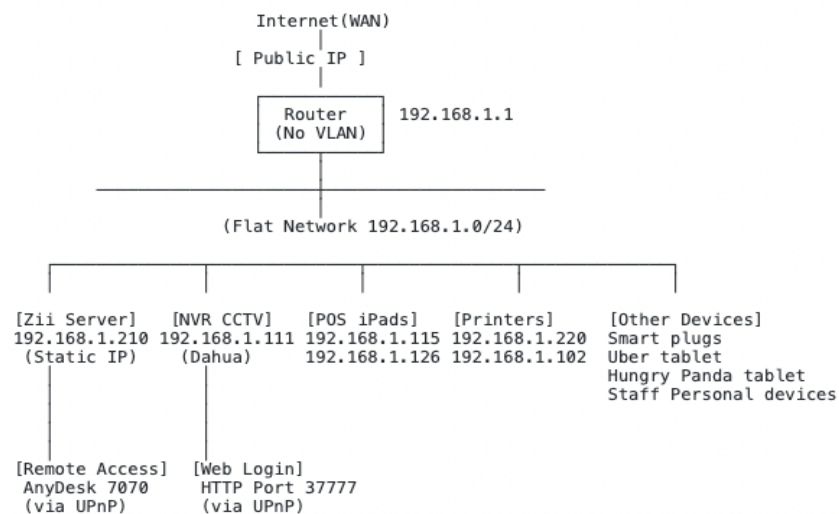


Figure 2 Network Topology of Taning Lemon Tea (Perth)

Key Risk: Flat network + exposed services → increased lateral movement and external attack surface

Router configuration

Default router credentials (High)

The router's administrative interface was accessible using default login credentials, as observed from the login page. This indicates that no changes have been made to the factory-set authentication settings.

Security Significance

This is a critical security issue because default credentials are widely known and easily accessible in public documentation. Attackers can use this information to gain unauthorized administrative access to the router without requiring advanced techniques.

Security and Operational Impact

The impact of this vulnerability is severe. An attacker who gains access to the router can modify network configurations, enable port forwarding, intercept traffic, or fully control all connected devices within the network.

Confidentiality: sensitive information may be exposed to unauthorised parties.

Integrity: attackers may change network settings or alter communications without permission.

Availability: internet services may be disrupted, or legitimate users may be blocked from normal network access.

Recommendation

It is recommended to immediately replace default credentials with strong, unique passwords and restrict administrative access to authorized users only.

HTTP management interface (High)

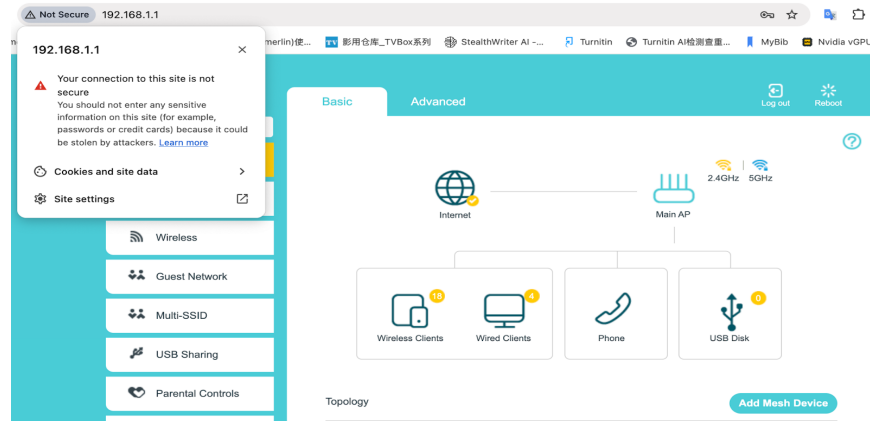


Figure 3 Router management interface using HTTP protocol

Description of the Vulnerability

An HTTP management interface refers to a web-based admin panel (e.g., router or system login page) that uses HTTP instead of HTTPS, meaning data is transmitted without encryption.

Security Significance

HTTP does not encrypt communication between the user and the system. This allows attackers on the same network to intercept sensitive information such as usernames and passwords.

Security and Operational Impact

Confidentiality: login credentials and other sensitive information may be exposed.

Integrity: attackers may gain unauthorised access and change device or system configurations.

Availability: compromised settings may disrupt services or prevent legitimate users from accessing the network properly.

Recommendation

It is recommended to disable HTTP management access and use HTTPS only for the administrative interface.

UPnP enabled (High)

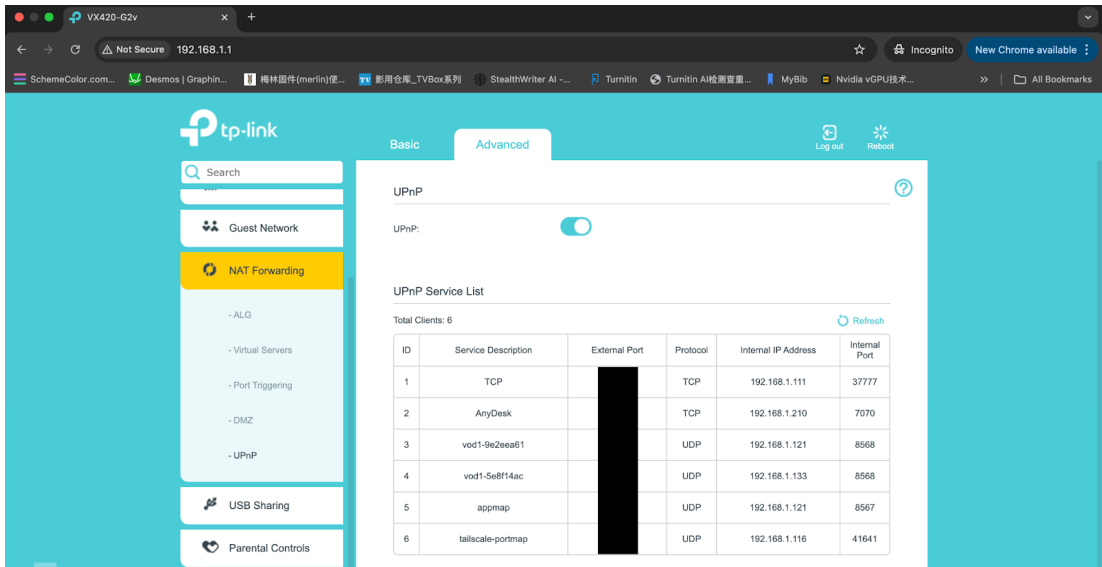


Figure 4 UPnP-enabled automatic port forwarding exposing internal services

Description of the Vulnerability

Universal Plug and Play (UPnP) is enabled on the router, allowing internal devices to automatically create port forwarding rules. As observed, the POS server (192.168.1.210) exposed TCP port 7070, and the Dahua NVR (192.168.1.111) exposed TCP port 37777 to the external network.

Security Significance

UPnP bypasses manual firewall controls, allowing devices to expose services externally without administrator awareness, significantly increasing the risk of unintended service exposure.

Security and Operational Impact

As shown in Figure 4, active UPnP port mappings are present for internal devices, including AnyDesk (port 7070) and Dahua NVR (port 37777), confirming automatic external exposure. This significantly increases the attack surface, allowing external attackers to directly interact with internal devices without authentication at the network boundary. If any exposed service is vulnerable or misconfigured, it may lead to unauthorized access, device compromise, or further lateral movement within the network.

Confidentiality: Internal services (e.g., POS, CCTV) may be accessed remotely without authorization.

Integrity: Attackers may exploit exposed services to modify system configurations or inject malicious actions.

Availability: Exposed services may be targeted to disrupt operations or cause denial-of-service conditions (e.g. DDoS to exposed port).

Recommendation

Disable UPnP on the router and manually control port forwarding rules; ensure only necessary services are exposed and restrict access via firewall rules or VPN.

Network Architecture

Flat network (High)

Network Configuration

IP Address: 192 . 168 . 1 . 1

Subnet Mask: 255.255.255.0

IGMP Snooping: ☒ Enable

Second IP: ☐ Enable

DHCP: ☒ Enable

☒ DHCP Server ☐ DHCP Relay

IP Address Pool: 192 . 168 . 1 . 2 - 192 . 168 . 1 . 240

Address Lease Time: 1440 minutes. (1-2880. The default value is 120.)

Default Gateway: 0 . 0 . 0 . 0 (Optional)

Default Domain: (Optional)

Primary DNS: 0 . 0 . 0 . 0 (Optional)

Secondary DNS: 0 . 0 . 0 . 0 (Optional)

Client List

Total Clients: 33 [Refresh](#)

ID	Client Name	MAC Address	Assigned IP
1	Unknown		192.168.1.102
2	Zii Server		192.168.1.210
3	Meross Smart Plug		192.168.1.100
4	Unknown		192.168.1.118
5	Meross Smart Plug		192.168.1.103

Navigation: 1 2 3 4 5 6 7

Figure 5 Router Configuration Showing Single Subnet Network

Description of the Vulnerability

All devices within the network are configured under a single subnet (e.g., 192.168.1.0/24), with no VLAN or network segmentation in place. As shown in Figure 5, the router configuration displays a single IP address pool (192.168.1.2 – 192.168.1.240), indicating that all devices operate within the same network segment without isolation.

Security Significance

A flat network allows unrestricted communication between all connected devices. If any device is compromised (e.g., via WiFi access or exposed services), attackers can easily move laterally across the network to access critical systems such as POS and NVR.

Impact:

The lack of network segmentation acts as a risk multiplier, eliminating defense-in-depth. Once a single device is compromised, an attacker can freely scan, access, and target all other devices within the LAN, significantly increasing the overall attack surface and potential impact of any initial breach.

Confidentiality: Unauthorized access to sensitive systems due to lack of network isolation

Integrity: Compromised devices can be used to alter configurations or data across the network

Availability: Malware or attacks can spread across the network, potentially disrupting multiple systems

Recommendation:

Implement network segmentation using VLANs to isolate critical systems (e.g., POS, CCTV, staff devices), and enforce access control rules between network segments.

Exposed External Services

AnyDesk port exposed (High)

Description of the Vulnerability

According to the official AnyDesk documentation (Figure 6), TCP port 7070 is used by default for direct peer-to-peer connections

- **General**
 - **Allow direct connections** - select the checkbox to allow faster, direct connections between clients. If disabled, sessions are routed through AnyDesk servers. All session data is end-to-end encrypted, regardless of connection type.
 - **Local port** - AnyDesk uses TCP port **7070** by default for direct connections. You can specify a custom port here.

Figure 6 Screenshot of AnyDesk document on describing port 7070

Security Significance

This allows external systems to initiate direct remote access sessions to the internal host, increasing the attack surface and enabling unauthorized access attempts.

Security and Operational Impact

Attackers may attempt unauthorized access through brute-force methods, abuse unattended access configurations, or exploit social engineering techniques to gain control.

Confidentiality: Unauthorized viewing of sensitive data in Zii POS Server via remote session

Integrity: Attackers can modify Zii POS Server configurations or files

Availability: Zii POS Server may be disrupted or locked via remote control, impacting the whole POS system.

Recommendation

As AnyDesk uses TCP ports 80/443/6568 to establish connections (Figure 7), port 7070 is not required, and recommended to be closed. AnyDesk can use outbound connections through relay servers without requiring inbound port exposure, any open ports for port forwarding should be disabled.

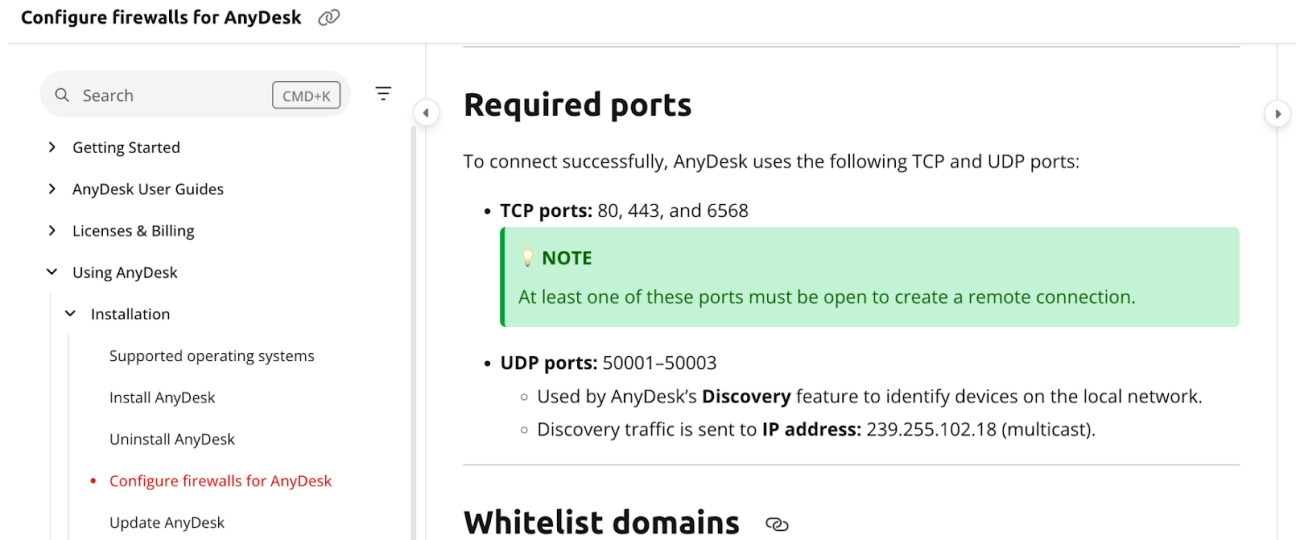


Figure 7 AnyDesk official documentation on required ports

CCTV / NVR TCP Port exposed (High):

Description of the Vulnerability

TCP port 37777 is exposed on the NVR (Network Video Recording) device (192.168.1.111), commonly associated with Dahua devices for remote control and video management functions. This port is believed to use a proprietary binary protocol, designed for device control functions, such as camera movement, recording configuration, etc.

Security Significance

This service allows remote interaction with the NVR device, significantly increasing the attack surface, especially if the device is exposed via port forwarding or UPnP.

Security and Operational Impact

Dahua NVR devices have a documented history of critical vulnerabilities affecting this port. In particular, if the device is running outdated firmware (with a version timestamp earlier than September 2021), it may be vulnerable to authentication bypass attacks (CVE-2021-33044). This vulnerability allows attackers to gain unauthorized access by sending a specially crafted packet that skips the password verification logic. This vulnerability has a CVSS score of 9.8 (Critical) and is listed in CISA's Known Exploited Vulnerabilities catalog.

Confidentiality: Unauthorized access to live and recorded video streams

Integrity: Attackers can modify configurations or recordings

Availability: Device disruption or complete takeover

Recommendation:

Verify firmware version and upgrade if outdated (pre-Sept 2021), and restrict access to port 37777 by disabling UPnP and blocking external exposure via firewall.

Physical Security Vulnerabilities

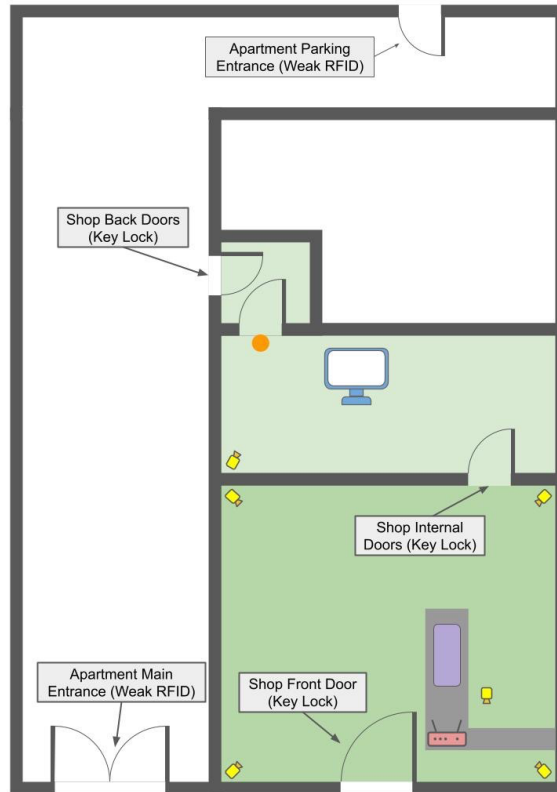


Figure 8 Physical Layout and Security Zones of Taning Lemon Tea (Perth)

Legend:

Deep Green = Main Service Area; Shallow Green = Staff room; Yellow = CCTV camera ; Blue = Monitoring PC ; Pink = Router; Purple = POS system ;Orange = Motion sensor

Access Control

Weak RFID card system (High)



Figure 9 Apartment Parking Entrance with RFID Access Control



Figure 10 RFID card dump shows default keys and access settings, indicating weak security and easy clonability.

Description of the Vulnerability

The apartment entrance's RFID card uses MIFARE Classic RFID cards (Figure 10) configured with default keys and default access settings, indicating a lack of proper encryption and secure configuration.

Security Significance

MIFARE Classic cards rely on outdated and vulnerable encryption mechanisms. When default keys are used, attackers can easily read and clone the card using widely available tools, without requiring advanced skills or equipment.

Security and Operational Impact

As shown in Figure 10, multiple sectors of the RFID card use default keys (FFFFFFFFFFFF) and default access control values (FF078069), confirming that the card is not securely configured and is susceptible to cloning and unauthorized access.

Confidentiality: Unauthorized individuals may gain access to restricted areas and sensitive environments

Integrity: Access control mechanisms can be bypassed or duplicated, undermining trust in the system

Availability: Unauthorized access may lead to disruption of operations or compromise of secured areas

Recommendation:

Replace MIFARE Classic cards with secure alternatives (e.g., MIFARE DESFire or encrypted smart cards), and ensure all access control systems use strong, unique keys and proper authentication mechanisms.

Unsecured back door (High)



Figure 11 Back door that connect staff room and apartment corridor with motion sensor

Description of the Vulnerability

While the back door has a lock and is used when the store is closed, during operation, the door remains unlocked and accessible. There is a sensor on the door that plays a sound when someone goes through, meaning it is detectable but not preventable.

Security Significance

The back door provides direct access to sensitive internal areas, including the staff room, monitoring systems, and operational assets. Although a sensor provides detection, it does not prevent unauthorized entry. During business hours, the unlocked state significantly increases the risk of unauthorized individuals gaining access without resistance, especially in an apartment environment with regular foot traffic.

Impact

This allows for theft, potential safety issues for staff and direct access to the monitoring computer allowing for any malicious system attacks such as destruction of data or files or theft of data. Ultimately allowing for unauthorised access.

Recommendation:

Enforce strict access control by keeping the door locked at all times and implementing electronic access mechanisms (e.g., RFID or keypad).

Device Security

Monitoring computer accessible without login (High)



Figure 12 The surveillance computer in the staff area can be accessed by anyone without any login

Description of the Vulnerability

The monitoring computer located in the staff area is accessible without any authentication, allowing any individual with physical access to use the system directly.

Security Significance

This computer provides access to live CCTV feeds and potentially other internal resources. Without login controls, there is no barrier preventing unauthorized users from viewing, modifying, or interacting with sensitive systems.

Impact:

Confidentiality: Unauthorized users can view live and recorded surveillance footage

Integrity: System settings, recordings, or configurations may be altered or deleted

Availability: The system can be disrupted, shut down, or misused, affecting monitoring capabilities

Recommendation:

Enforce user authentication (e.g., password or account-based login), implement automatic screen locking, and restrict physical access to authorized personnel only.

No USB restriction (High)

The staff room computer allows unrestricted use of USB ports, enabling any user to connect external storage devices without control or authentication.

Security Significance

Unrestricted USB access allows attackers to easily introduce malware, extract sensitive data, or execute unauthorized programs through removable media.

Impact:

As shown in Figure 12, the monitoring workstation is physically accessible and actively in use without visible restrictions, indicating that USB ports are exposed and available for use by any individual with physical access.

Confidentiality: Sensitive data (e.g., surveillance footage) can be copied to external devices

Integrity: Malicious software can be introduced to alter system behavior or data

Availability: Malware or unauthorized actions may disrupt or disable system operations

Recommendation:

Disable or restrict USB ports via system policies, implement endpoint protection controls, and limit physical access to authorized personnel only.

Surveillance

No major CCTV blind spots observed (Informational)

A review of the CCTV camera placement indicates that all critical areas are covered, including entrances, the cashier area, and the computer for the monitor. As the floor plan Figure 14 showed 4 cameras at the angle of the customer area covering all the entrances in the main service area; 1 camera above the cash machine covering the POS area; 1 camera at the staff room covering the back entrance and the monitoring computer.

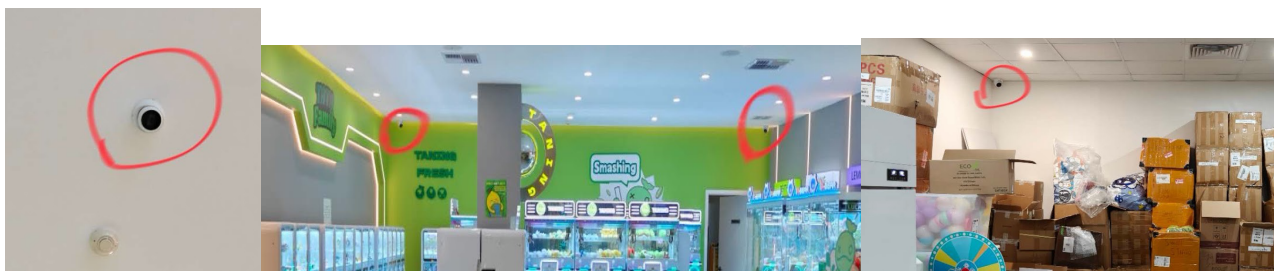


Figure 13 POS area monitored by overhead camera

Figure 13 Front entrance view covered by dual cameras

Figure 15 Staff room camera covering back door access and monitoring computer

Security Significance

Proper camera coverage reduces the risk of unauthorized activities going undetected and strengthens overall physical security monitoring.

Impact:

No significant CCTV blind spots were identified, as all critical areas—including entry points, the monitoring computer, and the POS/cashier area—are covered by cameras. This reduces the risk of undetected physical intrusion or unauthorized activities, supporting effective monitoring and incident investigation. As a result, physical security visibility is strong, and no immediate risks related to surveillance coverage were observed.

Integrated Risk Path Analysis

While each vulnerability presents individual risk, their combination creates a more significant security concern.

For example, an attacker who gains access to the WiFi network (due to weak password or exposed credentials) can then interact with internal systems within the flat network architecture.

This enables lateral movement to critical devices such as the POS server or NVR system, which are further exposed through insecure configurations (e.g., HTTP access, open ports, UPnP).

This chain of weaknesses demonstrates how relatively simple misconfigurations can escalate into full system compromise.

2.3 Aussie Moppy cleaning company

The investigated community is a local cleaning company named Aussie moppy operating in Perth, providing residential and commercial cleaning services. The business relies on a combination of manual processes and digital tools to manage client bookings, staff scheduling and communication. Staff frequently access client properties using provided keys, details or instructions communicated through mobile devices.

The organisation handles sensitive information including client addresses, access instructions, contact details and employee scheduling data. Due to the distributed nature of the workforce and reliance on trust-based operations, both physical and cybersecurity controls are critical. However, like many small-to-medium enterprises, the company does not appear to have formal cybersecurity policies, structured access controls or dedicated IT management, increasing exposure to both insider and external threats.

Security Issues Identified

Issue	Observed Weakness	Likely Impact	Priority
Lack of traceable access control	Shared keys used across staff without logging	No accountability, unauthorized property access	High
Insecure handling of client access information	Access instructions shared via messaging apps or stored informally	Direct exposure of entry methods to attackers	High
Weak authentication practices	Use of simple or reused passwords across accounts.	Account compromise through credential guessing or reuse attacks	High
Lack of multi-factor authentication	Critical accounts (email, social media) protected only by passwords	Increased susceptibility to phishing and account takeover	High
Flat network / device environment	No separation between staff devices and business systems	Lateral movement if one device is compromised	High
Use of personal devices (BYOD)	Staff use personal phones for work-related communication	Data leakage, loss or theft of sensitive information	High
Physical–cyber overlap exposure	Office or admin devices accessible without strict control	Full system compromise through physical access	High
Lack of staff security awareness	No training on phishing, scams or secure data handling	Increased success rate of social engineering attacks	High
Poor data storage practices	Client data stored in unencrypted formats (e.g., spreadsheets, notes, excel)	Confidentiality breach if accessed or leaked	High
Unlocked workstation	Staff leave systems unlocked in accessible areas	Unauthorised access, data exposure, loss of accountability	High
Third-party platform dependency	Use of external apps (e.g., Sling) without full control over security	Data exposure, service disruption, supply chain risk	High
Shared WiFi network	Same network used by staff and potentially accessible externally	Network intrusion, data interception, lateral movement	High
Insecure password storage	Passwords written near systems	Immediate credential compromise, unauthorized access	High
Weak location-based access control	Login allowed within large geographic range	Unauthorized remote access using stolen credentials	High
Lack of least system access	Staff may access more data than necessary	Increased insider threat impact, data misuse	High
Lack of logging and monitoring	No tracking of system activity or access	Undetected breaches, no forensic capability	Medium
Over-reliance on trust-based operations	Security depends on staff behaviour rather than controls	Insider threats, lack of accountability	High
Absence of defence-in-depth	No layered security mechanisms	Single point of failure leading to full compromise	High

Details and Impact of the Security Issues Identified

1. Lack of Traceable Access Control

The company relies on shared physical keys or alarm codes to grant staff access to client properties. This creates a major accountability problem because access cannot be linked to a specific individual. If an incident occurs, such as theft, damage, or unauthorised entry, there is no reliable audit trail to identify who was responsible. This weakens non-repudiation and increases the risk of insider threats.

2. Insecure Handling of Client Access Information

Client entry details and access instructions are often communicated through informal channels such as messaging applications. These platforms are not intended for the secure storage of sensitive operational information. If a staff member's phone is lost, compromised, or accessed by another person, attackers could obtain information that gives them direct access to client premises. This creates a serious confidentiality risk with physical and operational consequences.

3. Weak Authentication Practices and Lack of MFA

The use of simple or reused passwords makes accounts more vulnerable to credential theft and unauthorised access. Without multi-factor authentication, one successful phishing attack or password leak could result in full account compromise. This may expose sensitive client information, staff communications, and business systems such as email or social media accounts. The absence of MFA significantly reduces the strength of access protection.

4. Flat Network and Device Environment

The lack of network segmentation means all devices operate within the same trust boundary. If one device is infected with malware or compromised through phishing, an attacker may be able to move laterally to other systems on the same network. This increases the overall impact of a single compromised device and shows a lack of defence-in-depth in the organisation's network design.

5. Use of Personal Devices (BYOD)

Allowing staff to use personal devices for business purposes introduces unmanaged security risks. Personal devices may not have strong passwords, encryption, updated software, or secure storage controls. If a device is lost, stolen, or infected with malware, business data may be exposed without the organisation even knowing. This weakens both confidentiality and control over sensitive information.

6. Lack of Logging and Monitoring

The organisation appears to have limited or no logging and monitoring in place. Without activity logs, it becomes difficult to detect suspicious behaviour, investigate incidents, or understand how a breach happened. This delays incident response and reduces the organisation's ability to contain damage. In practice, it means security issues may go unnoticed for a long time.

7. Physical–Cyber Overlap Exposure

Physical access to offices, storage areas, or operational spaces can also create cybersecurity risks. Someone with direct physical access may be able to interact with computers, routers, documents, or other systems without needing to bypass digital protections first. This could allow malware installation, data theft, or credential resetting. It shows that physical security weaknesses can directly undermine cybersecurity controls.

8. Lack of Staff Security Awareness

Staff appear to have limited awareness of common cybersecurity threats such as phishing emails, scam calls, suspicious links, and unsafe data handling practices. Since human error is one of the most common causes of security incidents, this creates a significant vulnerability. Attackers often rely on social engineering to exploit staff behaviour rather than technical weaknesses alone.

9. Poor Data Storage Practices

Client information is likely stored in unencrypted files such as spreadsheets, notes, or shared documents. If these files are accessed by unauthorised individuals, the information can be read immediately and misused. This directly affects confidentiality and may lead to privacy breaches, reputational harm, or loss of client trust. It also suggests that sensitive data is not being handled according to basic security principles.

10. Over-Reliance on Trust-Based Operations

Many of the organisation's processes appear to depend on trust rather than technical enforcement. Examples include shared keys, informal communication of sensitive information, and unrestricted access to devices or data. Trust-based operations may work under normal conditions, but they fail when an employee is careless, negligent, or malicious. This increases exposure to insider threats, accidental misuse, and weak accountability.

The identified vulnerabilities were analysed using the CIA triad model to evaluate their impact on confidentiality, integrity and availability of systems and data.

Issue	Confidentiality	Integrity	Availability
Unlocked workstation	✓	✓	✗
Lack of traceable access control	✓	✓	✗
Weak authentication practices	✓	✓	✗
Shared WiFi network	✓	✓	✓
Flat network architecture	✓	✓	✓
Poor data storage practices	✓	✗	✗
Third-party platform dependency	✓	✓	✓
Lack of logging and monitoring	✗	✓	✓

Recommendations to Mitigate the Security Issues Identified

1. Implement accountable access control:

Replace shared keys with individualised access methods such as logged key systems or digital locks. Maintain records of access to ensure accountability and support incident investigation.

2. Secure handling of access information:

Avoid sharing sensitive client entry details through informal messaging platforms. Instead, limit exposure by providing only necessary information and ensuring it is not stored long-term on personal devices.

3. Strengthen authentication mechanisms:

Enforce strong password policies (minimum length and complexity) and eliminate password reuse. Enable multi-factor authentication (MFA) on all critical systems to reduce the risk of phishing-based attacks.

4. Introduce network segmentation:

Separate business-critical systems from general staff or guest networks. This reduces lateral movement and limits the impact of a compromised device.

5. Control use of personal devices (BYOD):

Implement minimum security requirements such as screen locks, updated software and restricted storage of sensitive data. Where possible, limit the use of personal devices for critical operations.

6. Enable logging and monitoring:

Implement basic logging of system access, login attempts and activity. Regularly review logs to detect suspicious behaviour and support incident response.

7. Restrict physical access to systems:

Ensure administrative systems and devices are in controlled environments. Enforce automatic screen locking and restrict unauthorised physical access.

8. Provide security awareness training:

Educate employees on phishing, social engineering, password hygiene, and safe data handling. Human awareness acts as a critical defensive layer.

9. Encrypt sensitive data:

Store client and employee data using encrypted solutions or secure cloud platforms to protect confidentiality in case of unauthorised access.

10 .Adopt a defence-in-depth approach:

Implement multiple layers of security (physical, authentication, network, and monitoring) to ensure that failure of a single control does not result in full system compromise.

Overall, the identified vulnerabilities highlight that the organisation's primary risks stem from weak access control, limited accountability and a lack of layered security measures.

Addressing these issues through practical and structured controls can significantly improve the organisation's security posture without disrupting its daily operations.

2.4 Forged Alliance: Forever

The Forged Alliance Forever community, an online community based around the game Supreme Commander: Forged Alliance. It is a community run preservation of the game with custom servers, matchmaking, mods, maps, rankings and balancing. It is an open-source project with a small team of developers and a consistent player base who use the product.

ICE (internet connectivity establishment) adapter leads to the servers being vulnerable to denial-of-service attacks

The game uses peer to peer connections as the original game was made when networking was too poor to run a central server. All inputs must be shared to all players and then the game state is derived locally. These inputs must pass through a full round trip every 500ms for the inputs to synchronise. Denial of service attacks could cause servers to shut down, forcing traffic to route only through the European server (precedent exists), leading to users in Australia who rely on the server relay connection to have their round-trip times to take over 500ms to communicate with others, causing major issues and ultimately massively affecting the availability of the game.

Remedial efforts include a rework to the ICE adapter to make the servers less vulnerable to DDoS attacks, potentially including a way to detect unusual player behaviour and limiting server access for unusually behaving users, potentially with AI integration. Fixing the DDoS issues then allows for more coturn servers to be run, allowing for better connections, especially in Australia and other Oceanian regions.

Social attacks

This service is community moderated so it can sometimes miss malicious behaviour or social engineering attempts. This could include but is not limited to, obtaining passwords and logins, obtaining personal information and the resulting impersonation ability.

To address this issue, automated chat moderation may be effective, scanning for activity that looks like people trying to obtain other's information. Another fix is general social awareness in the form of news posts or notifications on game start. These would give community members a baseline understanding and awareness of how to protect themselves from threats.

Vulnerabilities stemming from integrated tools

Many open-source tools are used within the custom tools of the ICE adapter and other programs. In the ICE adapter in particular, old versions of Jackson core, json smart, logback and eclipse jetty have had vulnerabilities such as DoS openings, overflows, remote code execution and improper shutdown. These have potential for major damage, particularly in the availability aspect.

The obvious fix is to update these tools to their newest versions which have no known vulnerabilities. This, however, has issues due to the sensitive nature of some programs making testing the new version difficult in the case that the updates change functionality in any way which is likely.

6. References

Australian Cyber Security Centre. (n.d.). Set secure passphrases. <https://www.cyber.gov.au/learn-basics/explore-basics/passphrases>

Australian Cyber Security Centre. (n.d.). Turn on multi-factor authentication. <https://www.cyber.gov.au/learn-basics/explore-basics/mfa>

Australian Cyber Security Centre. (2025, May 29). Social engineering. <https://www.cyber.gov.au/threats/types-threats/social-engineering>

McDonald's Australia. (2026, January 22). Privacy policy. <https://www.mcdonalds.com/au/en-au/privacy-policy.html>

Office of the Australian Information Commissioner. (2022). Guide to securing personal information. <https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/handling-personal-information/guide-to-securing-personal-information>

Office of the Australian Information Commissioner. (2025, October 3). Chapter 11: APP 11 - Security of personal information. <https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-11-app-11-security-of-personal-information>

Verizon. (2023). *2023 Data breach investigations report*. <https://www.verizon.com/business/resources/reports/dbir/>

Whitman, M. E., & Mattord, H. J. (2022). *Principles of information security (7th ed.)*. Cengage Learning.